RESERVE BANK OF INDIA

Department of Regulation

Title: Master Direction on Protection of Customer Data and Digital Privacy, 2026

Reference number: RBI/2026-27/74 DOR.PRV.REC/12/2026

Date: September 14, 2026

1. Governance and Rights

1.1 These Directions shall apply to all Regulated Entities processing customer personal data, and each entity shall appoint a Data Protection Officer and maintain an inventory of personal-data processing activities reviewed at least once every twelve months.

1.2 Regulated Entities shall collect customer data only for stated purposes with recorded consent, and consent-management records shall demonstrate purpose limitation across digital onboarding journeys.

1.3 Regulated Entities shall honour customer requests for access, correction and erasure of personal data within 30 days of receipt, and request fulfilment records shall be retained for supervisory inspection.

2. Security and Sharing

2.1 Regulated Entities shall protect customer data with encryption at rest and in transit, and stored card data shall be tokenised with coverage certified at least once every twelve months.

2.2 Regulated Entities shall notify the Reserve Bank of personal-data breaches within 24 hours of confirmation and affected customers within 72 hours, with root-cause reports submitted within 30 days of containment.

2.3 Regulated Entities shall define retention and anonymisation schedules for customer datasets, and data retained beyond the schedule shall carry documented justification approved by the Data Protection Officer.

2.4 Regulated Entities shall govern third-party sharing of customer data through agreements covering purpose, security controls and audit rights, and processors shall be audited at least once every twelve months.

3. Assessment and Culture

3.1 Regulated Entities shall conduct Data Protection Impact Assessments before launching new digital products handling customer data, and high residual risks shall require mitigation sign-off before launch approval.

3.2 Regulated Entities shall deliver privacy training to customer-facing staff at least once every twelve months, and completion shall be reported to the Board with consequences for persistent non-completion.

3.3 Regulated Entities shall control cross-border transfers of customer data through documented safeguards, and transfers to jurisdictions lacking adequate protection shall require Board-level approval with customer notice.